

# Controls & Compliance Readiness Assessment

Cross-framework control review with evidence, gaps, ownership, remediation, and closure criteria

## Assessment Note

This portfolio work sample demonstrates how a junior GRC/security analyst can organize control testing across common frameworks.

It is not a certification, attestation, legal opinion, or audit of a real organization.

| Domain                        | Framework examples                                                  | Expected evidence                                     | Representative gap                                     | Risk   | Remediation / closure                                                                |
|-------------------------------|---------------------------------------------------------------------|-------------------------------------------------------|--------------------------------------------------------|--------|--------------------------------------------------------------------------------------|
| Access control                | SOC 2 CC6; PCI DSS access; GDPR security; ISO access-control themes | IAM exports, approvals, MFA settings, access reviews  | Privileged review not consistently evidenced           | High   | Quarterly recertification; remove excess rights; retain approval/removal evidence.   |
| Encryption                    | PCI DSS; GDPR Art. 32; SOC 2 CC6; ISO crypto themes                 | TLS configs, storage encryption, key records          | Encryption evidence incomplete for selected data flows | High   | Validate coverage; document key ownership/rotation; close gaps or approve exception. |
| Logging                       | SOC 2 CC7; PCI DSS logging; ISO logging themes                      | SIEM sources, retention, alert rules, review records  | Critical admin events missing from central monitoring  | High   | Onboard sources; validate parsing, retention, alerting, and review ownership.        |
| Incident response             | SOC 2 CC7; PCI DSS IR; GDPR breach process; ISO incident management | IR plan, contact tree, exercises, incident records    | Escalation workflow not recently tested                | High   | Run tabletop; validate contacts; record lessons learned and corrective actions.      |
| Business continuity           | SOC 2 availability; ISO continuity themes                           | BCP/DR plan, RTO/RPO, restore tests                   | Restore evidence stale                                 | Medium | Complete recovery exercise; document results, failures, and corrective actions.      |
| Vendor risk                   | SOC 2 vendor oversight; GDPR processors; ISO supplier themes        | Due diligence, contracts, reviews, access inventory   | High-risk vendors lack consistent annual reassessment  | Medium | Tier vendors; annual reassessment; track findings and contract/security changes.     |
| Data minimization / retention | GDPR principles; ISO information lifecycle themes                   | Data inventory, retention schedule, deletion evidence | Retention exceptions not centrally tracked             | Medium | Create owner-based exception register; expiry reviews; deletion validation.          |

## Readiness Status Definitions

| Status              | Meaning                                                                          |
|---------------------|----------------------------------------------------------------------------------|
| Effective           | Control is designed appropriately and current evidence supports operation.       |
| Partially Effective | Control exists but scope, consistency, evidence, or operation needs improvement. |
| Not Effective       | Control is absent or does not adequately address the objective.                  |
| Not Applicable      | Control objective does not apply; rationale is documented and approved.          |

## Audit-Ready Evidence Rules

- Evidence must match the correct system, control, population, and assessment period.
- Policy alone is not enough when the objective requires operational proof.
- Samples should be traceable to approvals, tickets, system output, or logs.
- Exceptions require owner, rationale, compensating controls, approval, and expiration.
- Closure requires validation that the gap is actually corrected.

## 90-Day Remediation Roadmap

- **0-30 days:** Close critical access/encryption gaps; confirm incident contacts; begin missing-log onboarding.
- **31-60 days:** Complete privileged-access review, tabletop exercise, and high-risk vendor reassessment.
- **61-90 days:** Complete restore test, validate remediation evidence, review exceptions, and publish control-health metrics.